

Data Governance Policy Document

Data Governance Policy Document

1. Introduction et Objectifs
 - a. Contexte
 - b. Objectif
 - c. Portée
2. Principes Fondamentaux de Data Governance
 - a. Principe de responsabilité
 - b. Principe de transparence
 - c. Principe de sécurité des données
 - d. Principe de qualité des données
 - e. Principe de conformité
 - f. Principe de minimisation des données
 - g. Principe des droits des utilisateurs
 - h. Principe d'amélioration continue
 - i. Principe d'utilisation éthique
3. Structure Organisationnelle et Gestion des Données
 - a. Rôles et Responsabilités
 - b. Comités de Gouvernance
 - c. Gestion des Données
4. Mise en Œuvre et Amélioration Continue
 - a. Surveillance et Audit
 - b. Formation et Sensibilisation
 - c. Révision et Amélioration de la Politique

1. Introduction et Objectifs

a. Contexte

Spotify gère quotidiennement un volume considérable de données variées, incluant des données personnelles des utilisateurs, des données opérationnelles, des métadonnées musicales et des données d'analyse essentielles à son activité.

b. Objectif

Ce document vise à établir un cadre complet de gouvernance des données pour Spotify, assurant la qualité, la sécurité et la conformité des pratiques de gestion des données, tout en soutenant les opérations mondiales.

c. Portée

Cette politique s'applique à toutes les données gérées par Spotify, y compris les données des utilisateurs, les données opérationnelles, les données des artistes et les données analytiques, et concerne tous les employés, partenaires et sous-traitants ayant accès à ces données.

2. Principes Fondamentaux de Data Governance

a. Principe de responsabilité

- Chaque donnée doit avoir un propriétaire clairement identifié
- Les responsabilités en matière de gouvernance des données doivent être clairement définies et documentées à tous les niveaux de l'organisation
- La chaîne de responsabilité doit être transparente et tracée
- Chaque acteur doit être formé et conscient de ses responsabilités dans la gouvernance des données

b. Principe de transparence

- Communication claire et compréhensible sur les pratiques de collecte et d'utilisation des données
- Système robuste de gestion du consentement, permettant aux utilisateurs de contrôler leurs données (conformité RGPD et CCPA)

c. Principe de sécurité des données

- Chiffrement de bout en bout pour les données personnelles et de paiement
- Contrôles d'accès stricts basés sur le principe du moindre privilège
- Conformité aux normes de sécurité (ex: PCI-DSS) et audits réguliers
- Plan de réponse aux incidents de sécurité
- Réalisation de tests de pénétration réguliers pour identifier les vulnérabilités potentielles
- Mise en place et maintenance d'une infrastructure réseau sécurisée avec protection par pare-feu

d. Principe de qualité des données

- Critères clairs pour l'exactitude, l'exhaustivité et la cohérence des données
- Audits trimestriels de la qualité des données et processus de correction

e. Principe de conformité

- Mise en place de processus pour répondre aux demandes d'accès, de rectification et de suppression des données (RGPD, CCPA)
- Évaluations d'impact sur la protection des données (EIPD) pour tout nouveau traitement à risque
- Revue annuelle de la conformité globale aux réglementations sur la protection des données

- Conformité au Payment Card Industry Data Security Standard (PCI-DSS) pour la protection des données de paiement
- Mise en place d'un mécanisme clair permettant aux utilisateurs de refuser la vente de leurs données personnelles (CCPA)
- Établissement d'un protocole de notification des violations de données dans les délais légaux
- Formation régulière du personnel sur les exigences réglementaires et les procédures de conformité

f. Principe de minimisation des données

- Collecte ciblée avec finalité clairement définie
- Limitation de la collecte aux données strictement nécessaires
- Politique de conservation avec durées définies et suppression automatisée des données obsolètes

g. Principe des droits des utilisateurs

- Garantie des droits d'accès, de rectification, d'effacement et de portabilité des données
- Tableau de bord intuitif pour la gestion des préférences de confidentialité
- Processus automatisé pour le droit à l'oubli, s'étendant à tous les systèmes
- Mise en place de procédures pour répondre aux demandes des utilisateurs dans les délais impartis par les réglementations

h. Principe d'amélioration continue

- Révision semestrielle des politiques et procédures de gouvernance des données
- Système de collecte des retours des utilisateurs et des employés
- Veille technologique et réglementaire avec partage des connaissances

i. Principe d'utilisation éthique

- Charte éthique pour l'utilisation des données et de l'IA
- Comité d'éthique indépendant pour l'évaluation des projets à haut risque
- Transparence et audits des algorithmes de recommandation (conformité niveau 1 AI Act)
- Protection spécifique des groupes vulnérables, notamment les mineurs

3. Structure Organisationnelle et Gestion des Données

a. Rôles et Responsabilités

- CDO - Chief Data Officer : Responsable de la stratégie de gouvernance des données. Supervise la mise en œuvre des politiques de gouvernance des données et assure l'alignement avec les objectifs stratégiques.
- Data Owners : Responsables des données au niveau des départements. Assurent la qualité, l'utilisation, la sécurité et la gouvernance des données. Garantissent la cohérence, l'intégrité et la conformité des données. Utilisent les données conformément aux politiques établies et signalent les anomalies.
- Data Stewards : Assurent la gestion opérationnelle des données selon leur domaine de spécialisation (sécurité, qualité ou conformité). Ils mettent en œuvre les processus, surveillent leur application et collaborent avec les utilisateurs.
- DPO - Data Protection Officer ou Délégué à la Protection des Données : Assure la conformité aux réglementations sur la protection des données et veille à la sécurité des données de l'entreprise.
- DCO - Data Compliance Officer : Responsable de la conformité aux réglementations en matière de protection des données à travers toute l'organisation.
- CISO - Chief Information Security Officer : Responsable de la sécurité des informations. Dirige le Data Security Council.
- DSM - Data Security Manager : Supervise les aspects quotidiens de la sécurité des données.
- DQM - Data Quality Manager : Supervise les aspects quotidiens de la qualité des données. Dirige le Data Quality Council.
- Chief Ethics Officer : Assure la gestion éthique des données. Participe au Comité d'éthique indépendant.

- Utilisateurs des Données : Les collaborateurs qui utilisent les données dans leur travail quotidien, sous la supervision des Data Owners et avec l'appui des Data Stewards.

b. Comités de Gouvernance

- Data Governance Committee : Comité principal de gouvernance des données. Définit et supervise la stratégie globale de gouvernance des données.
- Data Security Council : Se concentre sur les aspects sécurité de la gouvernance des données.
- Data Quality Council : Assure le suivi et l'amélioration de la qualité des données à l'échelle de l'organisation.

c. Gestion des Données

- Collecte : Procédures pour une collecte légale et éthique, avec consentement explicite pour les données personnelles. Documentation claire de la finalité de chaque collecte de données
- Stockage : Solutions sécurisées, classification des données et politiques de rétention définies. Mise en œuvre du chiffrement pour protéger les données sensibles stockées.
- Accès : Système basé sur le principe du moindre privilège, avec audits réguliers et authentification forte. Mise en place d'une authentification à facteurs multiples pour l'accès aux systèmes critiques.
- Partage : Protocoles sécurisés, accords de confidentialité avec les tiers et traçabilité des partages. Évaluation rigoureuse des partenaires tiers avant tout partage de données.

4. Mise en Œuvre et Amélioration Continue

a. Surveillance et Audit

- Mise en place d'un tableau de bord pour suivre les métriques clés de gouvernance des données
- Rapports mensuels sur la conformité, la qualité des données et les incidents de sécurité
- Audits externes annuels avec publication des résultats dans le rapport de transparence

b. Formation et Sensibilisation

- Formation annuelle obligatoire pour tous les employés et formations spécialisées pour les équipes manipulant des données sensibles
- Communication interne régulière sur les bonnes pratiques et création d'une plateforme de partage des connaissances

c. Révision et Amélioration de la Politique

- Comité multidisciplinaire trimestriel pour évaluer et améliorer les pratiques de gouvernance
- Système de retour d'expérience des employés et révision annuelle de la politique pour refléter les évolutions réglementaires et technologiques